

Authentication protocols: PKI

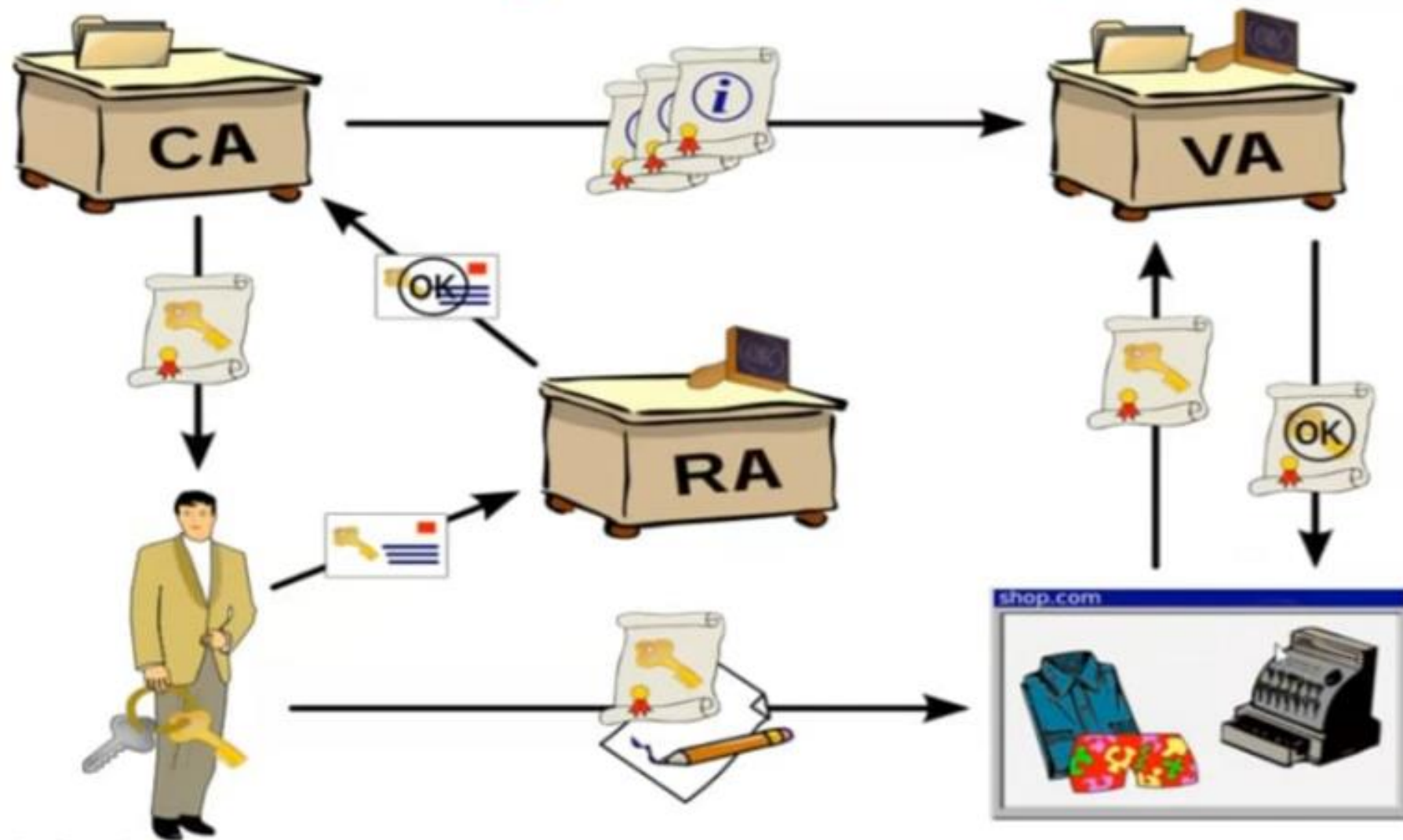
Public Key Infrastructure (PKI)

- Public key infrastructure is an important aspect of internet security.
- It is the set of technology and processes that make up a framework of encryption to protect and authenticate digital communications.
- Standard followed for managing, storing, and revoking the digital certificate.
- PKI uses cryptographic public keys that are connected to a digital certificate, which authenticates the device or user sending the digital communication.
- Digital certificates are issued by a trusted source, a certificate authority (CA), and act as a type of digital passport to ensure that the sender is who they say they are.

Main components of public key infrastructure

- **Certificate authority (CA):** The CA is a trusted entity that issues, stores, and signs the digital certificate. The CA signs the digital certificate with their own private key and then publishes the public key that can be accessed upon request.
- **Registration authority (RA):** The RA verifies the identity of the user or device requesting the digital certificate. This can be a third party, or the CA can also act as the RA.
- **Certificate database:** This database stores the digital certificate and its metadata, which includes how long the certificate is valid.
- **Central directory:** This is the secure location where the cryptographic keys are indexed and stored.
- **Certificate management system:** This is the system for managing the delivery of certificates as well as access to them.
- **Certificate policy:** This policy outlines the procedures of the PKI. It can be used by outsiders to determine the PKI's trustworthiness.

Public Key Infrastructure (PKI)



Why is PKI used?

- One of the most common uses of PKI is the TLS/SSL (transport layer security/secure socket layer), which secures encrypted HTTP (hypertext transfer protocol) communications.
- Website owners will obtain a digital certificate from a trusted CA.
- To be issued a CA, the owner of the website will have to prove that they are indeed the actual owner.
- Once verified, the website owner can purchase an SSL certificate to install on the web server.
- This tells the browser that it is the legitimate website the browser is trying to access.

Uses for PKI

- Email encryption and authentication of the sender
- Signing documents and software
- Using database servers to secure internal communications
- Securing web communications, such as e-commerce
- Authentication and encryption of documents
- Securing local networks and smart card authentication
- Encrypting and decrypting files
- Secure communication between mutually trusted devices such as IoT (internet of things) devices

- Digital certificates are also called PKI certificates or X.509 certificates. A PKI certificate offers proof of identity to a requesting entity, which is verified by a third party and works like a digital passport or driver's license.
- The PKI certificate will contain the following:
 - Distinguished name (DN) of the owner
 - Owner's public key
 - Date of issue
 - Expiration date
 - DN of the issuing CA
 - Issuing CA's digital signature

X.509 certificate

• Authentication Application

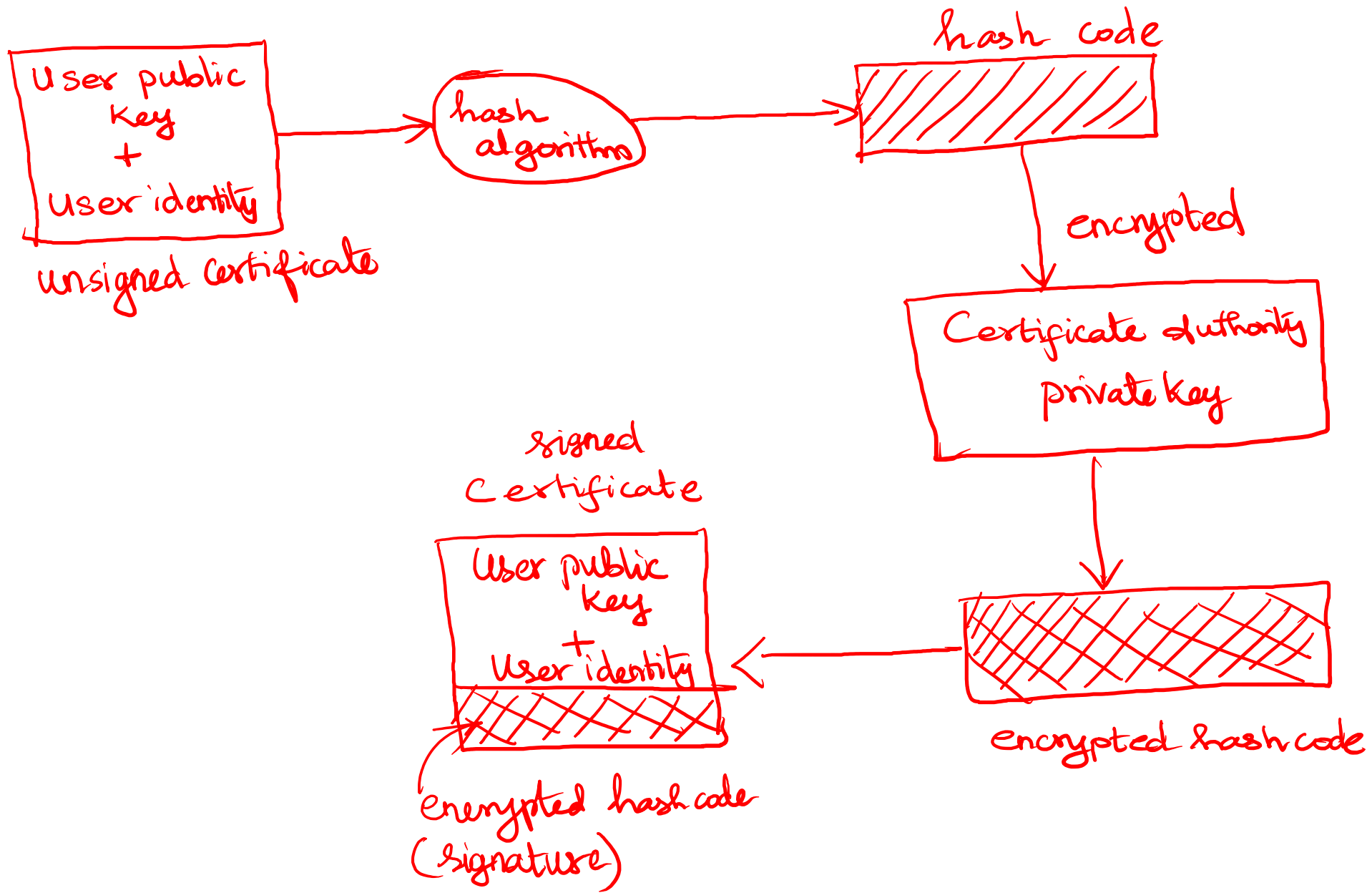
- Authentication means verifying the user identity.
- If two users want to communicate with each other, they should be mutually authenticated.
- Once the authentication process is completed, the communication takes place between them.
- This mutual authentication can be done in different ways : Applying the Kerberos concept or by using X.509 certificate.

(Key) * private key } one is used for encryption and other for decryption.
public key }
 → Not Sharable
 → public access.

Certificate Authority
↳ is one of the option to maintain the certificate of public keys

Certification Authority

- * It is not responsible to generate public keys
- * Trusted third party
- * provides easy way to access this public keys and for authentication.
- * It will generate a signature [encryption using private key of the Sender]
- * This signature is generated for user's public key and the user's identity.



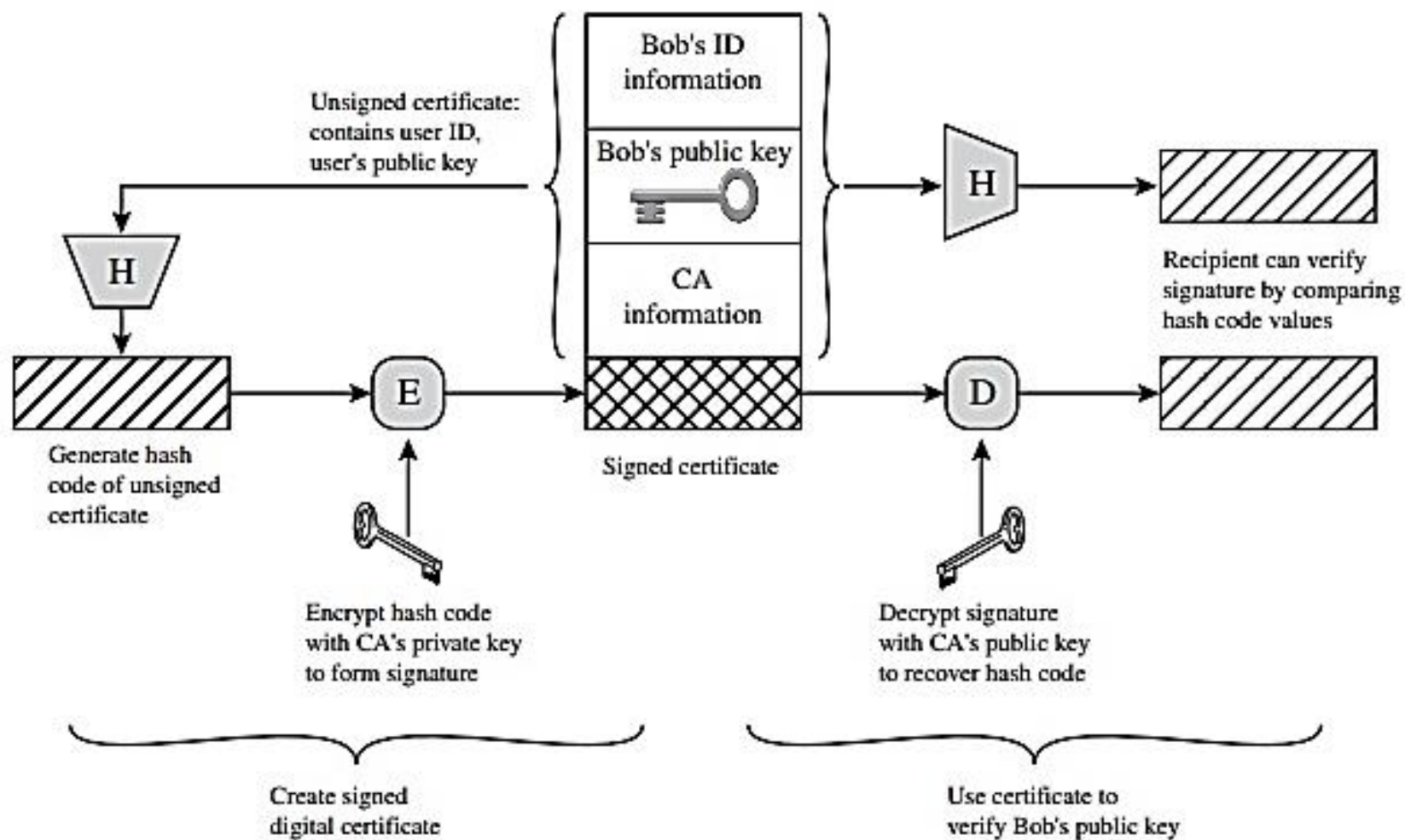


Figure 14.13 Public-Key Certificate Use

X.509 certificate

- An X.509 certificate is a digital certificate that uses the widely accepted international X.509 public key infrastructure (PKI) standard to verify that a public key belongs to the user, computer or service identity contained within the certificate.
- An X.509 certificate contains information about the identity to which a certificate is issued and the identity that issued it. Standard information in an X.509 certificate includes:
 - **Version – which X.509 version applies to the certificate (which indicates what data the certificate must include)**
 - **Serial number – the identity creating the certificate must assign it a serial number that distinguishes it from other certificates**
 - **Algorithm information – the algorithm used by the issuer to sign the certificate**
 - **Issuer distinguished name – the name of the entity issuing the certificate (usually a certificate authority)**
 - **Validity period of the certificate – start/end date and time**
 - **Subject distinguished name – the name of the identity the certificate is issued to**
 - **Subject public key information – the public key associated with the identity**
 - **Extensions (optional)**
- Many of the certificates that people refer to as Secure Sockets Layer (SSL) certificates are in fact X.509 certificates.
- The first X.509 certificates were issued in 1988 as part of the International Telecommunications Union's Telecommunication Standardization Sector (ITU-T) and the X.500 Directory Services Standard. In 1993, version 2 added two fields to support directory access control. Version 3 was released in 1996 and defines the formatting used for certificate extensions.

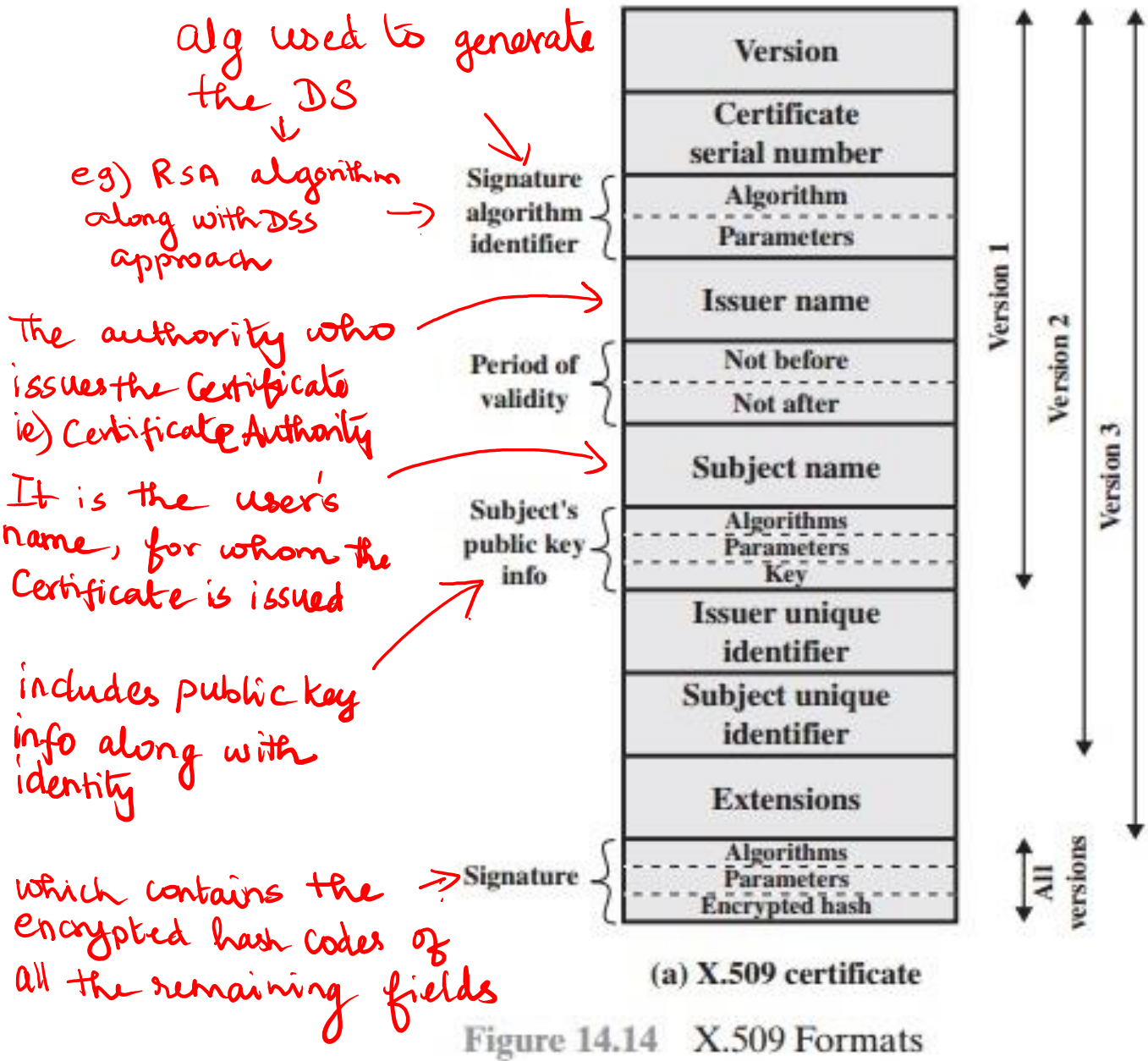
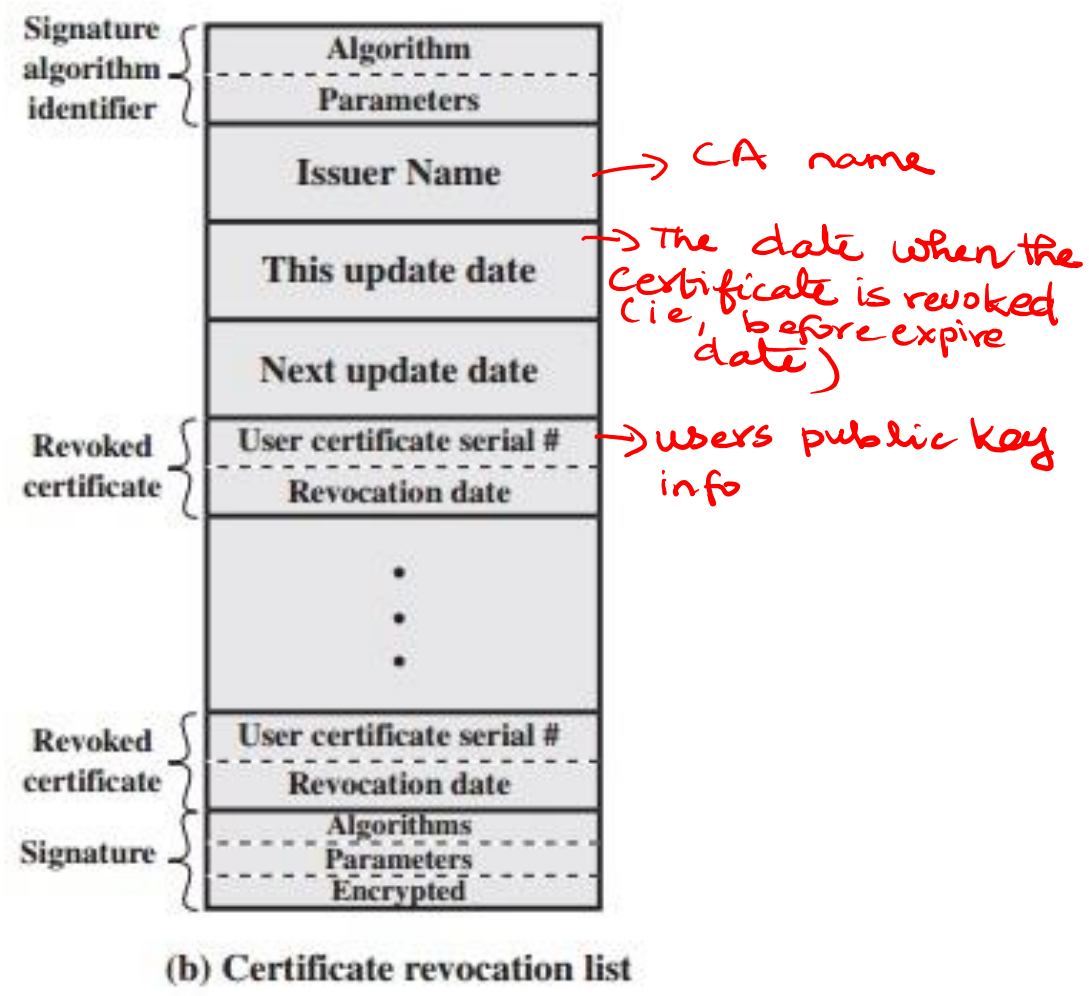


Figure 14.14 X.509 Formats



Note: After a period of time, the Certificate will be expired. So it shd be renewed before expire date. Those ^{revoked} Certificates will be stored in the revocation list.